

IoT Water System Security

How layered controls protected the hotel's water-monitoring pipeline

Sok Leng Chan · Cybersecurity Extern · August 2026

Unprotected MQTT Traffic Exposes Hotel Operations

Three realistic attack paths can turn sensor access into service disruption, property risk, and poor operational decisions.

Eavesdropping

Without encryption, someone on the network could read pressure and flow values. The data reveals operating patterns and can support a later attack.

Data Injection

A forged reading can trigger false alarms, unnecessary shutoffs, or unsafe decisions. Device and message checks prevent fake data from appearing trusted.

Replay Attacks

An attacker can resend an old valid reading to hide a new leak or pressure spike. Freshness checks reject stale, duplicate, and out-of-order data.

Business impact: compromised telemetry can disrupt service, damage property, and undermine guest trust.

Four Defenses Close Four Different Security Gaps

Each layer proves a different part of trust: a private connection, an approved device, an unchanged message, and a current reading.

Defense 1

TLS

Encrypts traffic between the publisher, broker, and subscriber. Stops network observers from reading or changing telemetry in transit.

Defense 2

mTLS

Both sides present trusted certificates before data is accepted. Blocks unknown devices, fake publishers, and unauthorized subscribers.

Defense 3

HMAC

Adds a keyed signature to every payload. Any change to the reading, device ID, timestamp, or sequence produces a mismatch and rejection.

Defense 4

Timestamp + Sequence

Rejects messages older than 30 seconds, duplicated, or out of order. Prevents captured valid messages from being reused.

Remove one layer and the system loses confidentiality, device trust, message integrity, or replay protection.

Only Validated Messages Reach the Dashboard

Controls operate at both the connection level and the individual-message level before staff can see or act on a reading.

1. SENSOR PUBLISHER

Creates pressure and flow readings
Adds timestamp, sequence, and HMAC

2. MOSQUITTO BROKER

Encrypts traffic with TLS
Verifies the device certificate with mTLS

3. SECURE SUBSCRIBER

Rebuilds and compares the HMAC
Checks message age and sequence order

4. DASHBOARD

Updates telemetry or records the rejection

Validation Flow

1. Connection trust — TLS encrypts the session; mTLS accepts only approved certificates.
2. Message integrity — HMAC confirms that protected fields were not changed after publishing.
3. Freshness — Messages older than 30 seconds, duplicated, or out of order are rejected.
4. Visible outcome — Valid data updates the gauges; rejected data is logged with the failure reason.

Combined Defenses Blocked Every Tested Attack

Each attack was stopped by the control designed for that failure mode, and no malicious reading reached the operational view.

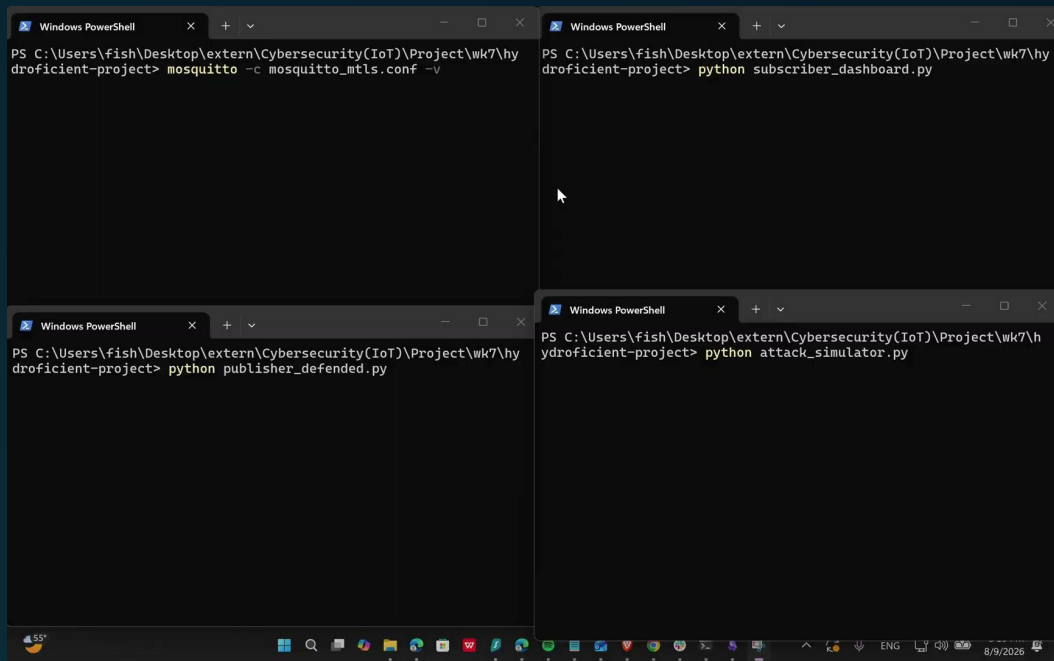
Attack	Attacker objective	Defense chain	Evidence and outcome
Eavesdrop	Read sensor traffic and operating patterns	TLS	Traffic remained encrypted; readable sensor payloads were not exposed
Inject fake data	Make a forged pressure or flow reading look trusted	mTLS + HMAC	Certificate and signature checks rejected untrusted or altered data
Replay	Resend a previously valid reading	Timestamp + sequence	Stale, duplicate, and out-of-order messages were rejected

0 of 15 attacks succeeded | 100% blocked

The Simulator Reproduced Each Attack on Demand

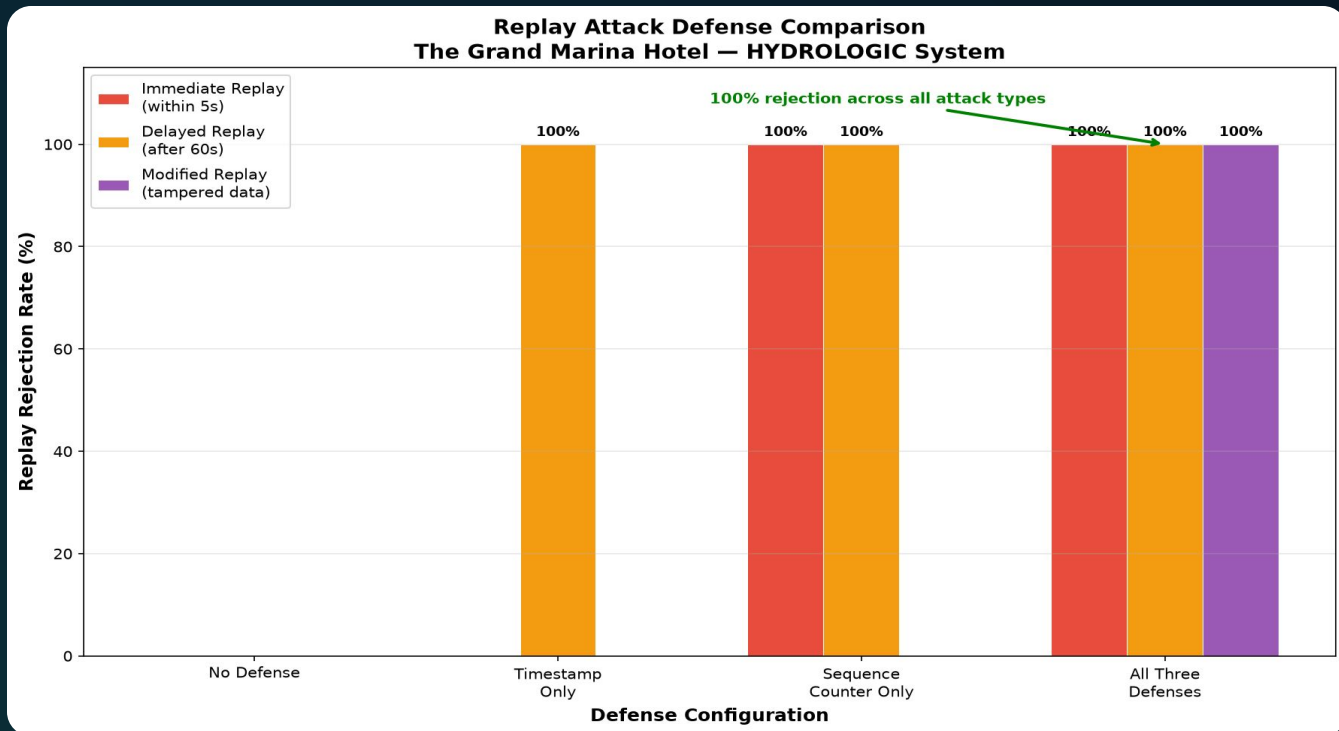
Separate terminals reproduced eavesdropping, false-data injection, and replay attempts. Each run verified terminal rejection and dashboard logging.

[Watch the live demonstration →](#)



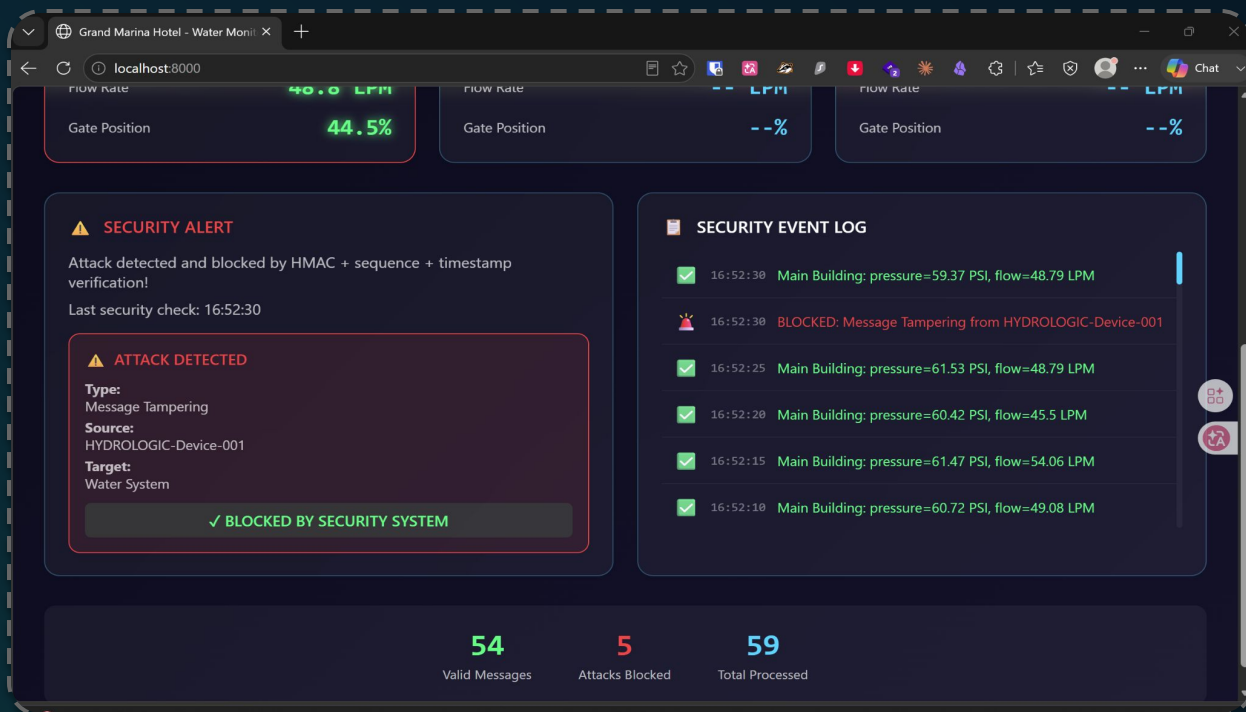
Replay Protection Required More Than One Check

Timestamp-only and sequence-only defenses each left replay variants uncovered. The complete defense chain rejected every replay tested.



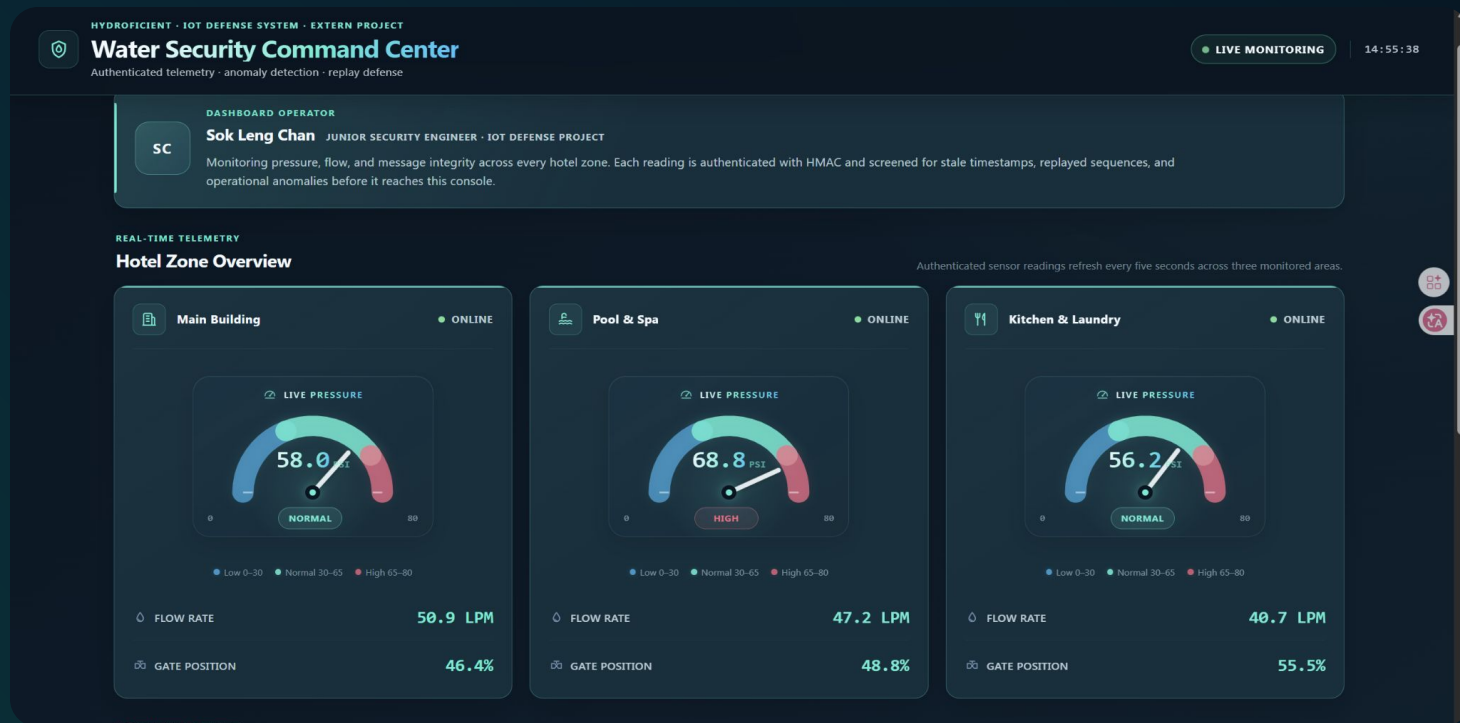
Every Valid Message Accepted; Every Attack Rejected

The dashboard processed 59 messages: 54 legitimate readings updated operations, while 5 attack messages were blocked and logged without interrupting normal telemetry.



One Dashboard Unifies Security and Operations

The operator sees live pressure, flow rate, gate position, device status, anomaly rules, and rejected-message evidence across three hotel zones.



Testing Revealed Four Production Priorities

The prototype worked—and clarified which controls, trust boundaries, tests, and limitations matter most for the next security cycle.

1

Layered controls are essential

mTLS proves device identity, HMAC protects every reading, and freshness checks block reuse. No single control covers all three failure modes.

2

Security must cover the full pipeline

Publisher, broker, subscriber, and dashboard are separate trust boundaries. A weakness in any stage can undermine the entire system.

3

Attack simulation validates assumptions

Normal operation only proves that data flows. Controlled attacks show whether forged, stale, and unauthorized messages fail for the expected reason.

4

The evidence has defined limits

The lab covered eavesdropping, injection, and replay. Production readiness also needs outage, certificate-theft, denial-of-service, and recovery testing.

Four Actions Move the Prototype Toward Production

Grand Marina can strengthen the protection while keeping ownership, monitoring, and recovery procedures clear for the operating team.

1

Automate certificate lifecycle

Issue, rotate, expire, and revoke device certificates automatically. A lost or stolen certificate should not remain trusted.

2

Protect signing keys

Store HMAC secrets outside source code and assign a unique key to each device. One compromised sensor should not expose the whole fleet.

3

Centralize security monitoring

Send broker logs, certificate failures, anomaly alerts, and dashboard rejections to one SIEM or monitoring queue with escalation rules.

4

Expand testing and recovery

Test certificate theft, denial-of-service, broker outages, and key rotation. Document response ownership, restoration steps, and evidence retention.

100% Blocked

15 simulated attacks rejected while legitimate telemetry continued to reach the dashboard.